

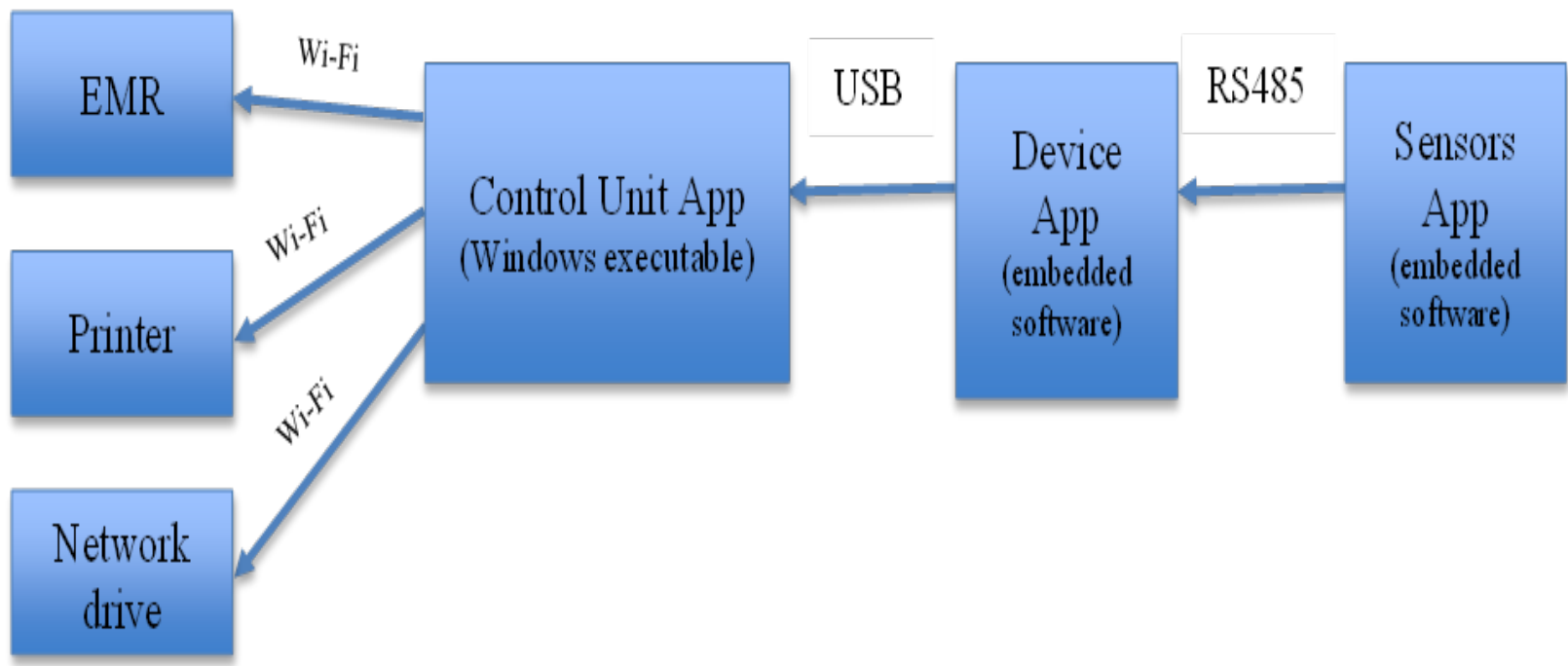
Manufacturer Disclosure Statement for Medical Device Security -- MDS2

PulmOne Advanced Medical Devices, Ltd	MiniBox+, SW Versions 3.2.0.0 to 3.3.0.0	PUO-DOCXXXX	30-Jan-2025
Question ID	Question	See note	
DOC-1	Manufacturer Name	PulmOne Advanced Medical Devices, Ltd	—
DOC-2	Device Description	Cabinless Pulmonary Function Testing Device	—
DOC-3	Device Model	MiniBox+, SW Versions 3.2.0.0 to 3.3.0.0	—
DOC-4	Document ID	PUO-DOCXXXX	—
		PulmOne USA Inc. 444 Madison Avenue, 6th Floor New York, NY 10022 1-888-635-9798 service@pulm-one.com	—
DOC-5	Manufacturer Contact Information		—
		The PulmOne MiniBox+ is intended to measure lung function in adult and pediatric patients, 5 years and older, while at rest (including spirometry, lung volumes and diffusing capacity). The PulmOne MiniBox+ is to be used by: a physician, respiratory therapist, or technician in a hospital or clinic setting.	
		In a network-connected environment, the MiniBox+ can receive/send HL7 Orders and Results.	—
DOC-6	Intended use of device in network-connected environment:		—
DOC-7	Document Release Date	30-Jan-2025	—
DOC-8	Coordinated Vulnerability Disclosure: Does the manufacturer have a vulnerability disclosure program for this device?	No	We use FDA-compliant processes on compliant handling and corrective & preventative actions (CAPA).
DOC-9	ISAO: Is the manufacturer part of an Information Sharing and Analysis Organization?	No	—
DOC-10	Diagram: Is a network or data flow diagram available that indicates connections to other system components or expected external resources?	Yes	See flow diagram to the right.
DOC-11	SaMD: Is the device Software as a Medical Device (i.e. software-only, no hardware)?	No	Device includes both Software & Hardware
DOC-11.1	Does the SaMD contain an operating system?	N/A	Device includes both Software & Hardware
DOC-11.2	Does the SaMD rely on an owner/operator provided operating system?	N/A	Device includes both Software & Hardware
DOC-11.3	Is the SaMD hosted by the manufacturer?	N/A	Device includes both Software & Hardware
DOC-11.4	Is the SaMD hosted by the customer?	N/A	Device includes both Software & Hardware

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013



	Yes, No, N/A, or See Note	Note #
MANAGEMENT OF PERSONALLY IDENTIFIABLE INFORMATION		
MPII-1	Can this device display, transmit, store, or modify personally identifiable information (e.g. electronic Protected Health Information (ePHI))?	Yes
MPII-2	Does the device maintain personally identifiable information?	Yes
MPII-2.1	Does the device maintain personally identifiable information temporarily in volatile memory (i.e., until cleared by power-off or reset)?	No
MPII-2.2	Does the device store personally identifiable information persistently on internal media?	Yes
MPII-2.3	Is personally identifiable information preserved in the device's non-volatile memory until explicitly erased?	Yes
MPII-2.4	Does the device store personally identifiable information in a database?	Yes
		Internal database on the hard drive (SQLite)
MPII-2.5	Does the device allow configuration to automatically delete local personally identifiable information after it is stored to a long term solution?	Yes
MPII-2.6	Does the device import/export personally identifiable information with other systems (e.g., a wearable monitoring device might export personally identifiable information to a server)?	Yes
MPII-2.7	Does the device maintain personally identifiable information when powered off, or during power service interruptions?	Yes
MPII-2.8	Does the device allow the internal media to be removed by a service technician (e.g., for separate destruction or customer retention)?	No
MPII-2.9	Does the device allow personally identifiable information records to be stored in a separate location from the device's operating system (i.e. secondary internal drive, alternate drive partition, or remote storage location)?	Yes
MPII-3	Does the device have mechanisms used for the transmitting, importing/exporting of personally identifiable information?	Yes
MPII-3.1	Does the device display personally identifiable information (e.g., video display, etc.)?	Yes
MPII-3.2	Does the device generate hardcopy reports or images containing personally identifiable information?	Yes
MPII-3.3	Does the device retrieve personally identifiable information from or record personally identifiable information to removable media (e.g., removable-HDD, USB memory, DVD-R/RW, CD-R/RW, tape, CF/SD card, memory stick, etc.)?	Yes
MPII-3.4	Does the device transmit/receive or import/export personally identifiable information via dedicated cable connection (e.g., RS-232, RS-423, USB, FireWire, etc.)?	No
MPII-3.5	Does the device transmit/receive personally identifiable information via a wired network connection (e.g., RJ45, fiber optic, etc.)?	See Notes
MPII-3.6	Does the device transmit/receive personally identifiable information via a wireless network connection (e.g., WiFi, Bluetooth, NFC, Infrared, cellular, etc.)?	Yes
MPII-3.7	Does the device transmit/receive personally identifiable information over an external network (e.g., Internet)?	No
MPII-3.8	Does the device import personally identifiable information via scanning a document?	No
MPII-3.9	Does the device transmit/receive personally identifiable information via a proprietary protocol?	No
MPII-3.10	Does the device use any other mechanism to transmit, import or export personally identifiable information?	No
Management of Private Data notes:		

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013

AUTOMATIC LOGOFF (ALOF)		
<i>The device's ability to prevent access and misuse by unauthorized users if device is left idle for a period of time.</i>		
ALOF-1	Can the device be configured to force reauthorization of logged-in user(s) after a predetermined length of inactivity (e.g., auto-logout, session lock, password protected screen saver)?	Yes
ALOF-2	Is the length of inactivity time before auto-logout/screen lock user or administrator configurable?	Yes

Section 5.1, ALOF

AC-12

None

Section 5.1, ALOF

AC-11

A.11.2.8, A.11.2.9

AUDIT CONTROLS (AUDT)		
<i>The ability to reliably audit activity on the device.</i>		
AUDT-1	Can the medical device create additional audit logs or reports beyond standard operating system logs?	Yes
AUDT-1.1	Does the audit log record a USER ID?	Yes
AUDT-1.2	Does other personally identifiable information exist in the audit trail?	Yes
	Are events recorded in an audit log? If yes, indicate which of the following events are recorded in the audit log:	No
AUDT-2	Successful login/logout attempts?	Yes
AUDT-2.1	Successful login/logout attempts?	Yes
AUDT-2.2	Unsuccessful login/logout attempts?	Yes
AUDT-2.3	Modification of user privileges?	Yes
AUDT-2.4	Creation/modification/deletion of users?	Yes
AUDT-2.5	Presentation of clinical or PII data (e.g. display, print)?	No
AUDT-2.6	Creation/modification/deletion of data?	Yes
AUDT-2.7	Import/export of data from removable media (e.g. USB drive, external hard drive, DVD)?	Yes
AUDT-2.8	Receipt/transmission of data or commands over a network or point-to-point connection?	Yes
AUDT-2.8.1	Remote or on-site support?	No
AUDT-2.8.2	Application Programming Interface (API) and similar activity?	N/A
AUDT-2.9	Emergency access?	N/A
AUDT-2.10	Other events (e.g., software updates)?	Yes
AUDT-2.11	Is the audit capability documented in more detail?	No
AUDT-3	Can the owner/operator define or select which events are recorded in the audit log?	No
AUDT-4	Is a list of data attributes that are captured in the audit log for an event available?	No
AUDT-4.1	Does the audit log record date/time?	Yes
	Can date and time be synchronized by Network Time Protocol (NTP) or equivalent time source?	Yes
AUDT-4.1.1	Can audit log content be exported?	Yes
AUDT-5	Via physical media?	Yes
AUDT-5.1	Via IHE Audit Trail and Node Authentication (ATNA) profile to SIEM?	No
AUDT-5.2		No
AUDT-5.3	Via Other communications (e.g., external service device, mobile applications)?	No

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013

Section 5.2, AUDT

AU-1

A.5.1.1, A.5.1.2, A.6.1.1, A.12.1.1, A.18.1.1, A.18.2.2

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

Section 5.2, AUDT

AU-2

None

PulmOne Advanced Medical Devices, Ltd	MiniBox+, SW Versions 3.2.0.0 to 3.3.0.0	PUO-DOCXXXX	30-Jan-2025			
AUDT-5.4	Are audit logs encrypted in transit or on storage media?	No	—			
AUDT-6	Can audit logs be monitored/reviewed by owner/operator?	Yes	May require assistance from PulmOne Customer Support			
AUDT-7	Are audit logs protected from modification?	No	—	Section 5.2, AUDT	AU-2	None
AUDT-7.1	Are audit logs protected from access?	Yes	Requires admin privileges			
AUDT-8	Can audit logs be analyzed by the device?	No	—	Section 5.2, AUDT	AU-2	None
AUTHORIZATION (AUTH) <i>The ability of the device to determine the authorization of users.</i>				IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
AUTH-1	Does the device prevent access to unauthorized users through user login requirements or other mechanism?	Yes	User login required	Section 5.3, AUTH	IA-2	A.9.2.1
AUTH-1.1	Can the device be configured to use federated credentials management of users for authorization (e.g., LDAP, OAuth)?	No	Accounts are local to the software, technician user (from PulmOne) or customer admin users can add/edit/delete individual accounts.	Section 5.3, AUTH	IA-2	A.9.2.1
AUTH-1.2	Can the customer push group policies to the device (e.g., Active Directory)?	See Notes	If the device is managed by the customer on a Domain	Section 5.3, AUTH	IA-2	A.9.2.1
AUTH-1.3	Are any special groups, organizational units, or group policies required?	See Notes	Group Policies only	Section 5.3, AUTH	IA-2	A.9.2.1
AUTH-2	Can users be assigned different privilege levels based on 'role' (e.g., user, administrator, and/or service, etc.)?	Yes	—	Section 5.3, AUTH	IA-2	A.9.2.1
AUTH-3	Can the device owner/operator grant themselves unrestricted administrative privileges (e.g., access operating system or application via local root or administrator account)?	See Notes	The user needs the Windows administrator password in order to log in as an administrator. The Windows admin password can be changed if requested.	Section 5.3, AUTH	IA-2	A.9.2.1
AUTH-4	Does the device authorize or control all API access requests?	N/A	—	Section 5.3, AUTH	IA-2	A.9.2.1
AUTH-5	Does the device run in a restricted access mode, or 'kiosk mode', by default?	Yes	KIOSK mode			
CYBER SECURITY PRODUCT UPGRADES (CSUP) <i>The ability of on-site service staff, remote service staff, or authorized customer staff to install/upgrade device's security patches.</i>				IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
CSUP-1	Does the device contain any software or firmware which may require security updates during its operational life, either from the device manufacturer or from a third-party manufacturer of the software/firmware? If no, answer "N/A" to questions in this section.	Yes	We release new software versions two times per year.			
CSUP-2	Does the device contain an Operating System? If yes, complete 2.1-2.4.	Yes	Windows 11			
CSUP-2.1	Does the device documentation provide instructions for owner/operator installation of patches or software updates?	Yes	—			
CSUP-2.2	Does the device require vendor or vendor-authorized service to install patches or software updates?	No	The device owner can install vendor-approved application software updates directly via USB.			
CSUP-2.3	Does the device have the capability to receive remote installation of patches or software updates?	See Notes	PulmOne technicians can remotely install application software updates if requested.			
CSUP-2.4	Does the medical device manufacturer allow security updates from any third-party manufacturers (e.g., Microsoft) to be installed without approval from the manufacturer?	No	—			
CSUP-3	Does the device contain Drivers and Firmware? If yes, complete 3.1-3.4.	Yes	—			
CSUP-3.1	Does the device documentation provide instructions for owner/operator installation of patches or software updates?	No	Only for device software updates, not for firmware, driver, or anti-malware software updates			
CSUP-3.2	Does the device require vendor or vendor-authorized service to install patches or software updates?	No	—			
CSUP-3.3	Does the device have the capability to receive remote installation of patches or software updates?	No	—			
CSUP-3.4	Does the medical device manufacturer allow security updates from any third-party manufacturers (e.g., Microsoft) to be installed without approval from the manufacturer?	No	—			
CSUP-4	Does the device contain Anti-Malware Software? If yes, complete 4.1-4.4.	Yes	—			
CSUP-4.1	Does the device documentation provide instructions for owner/operator installation of patches or software updates?	No	Only for device software updates, not for firmware, driver, or anti-malware software updates			
CSUP-4.2	Does the device require vendor or vendor-authorized service to install patches or software updates?	No	—			
CSUP-4.3	Does the device have the capability to receive remote installation of patches or software updates?	No	—			
CSUP-4.4	Does the medical device manufacturer allow security updates from any third-party manufacturers (e.g., Microsoft) to be installed without approval from the manufacturer?	No	—			
CSUP-5	Does the device contain Non-Operating System commercial off-the-shelf components? If yes, complete 5.1-5.4.	No	—			
CSUP-5.1	Does the device documentation provide instructions for owner/operator installation of patches or software updates?	N/A	—			
CSUP-5.2	Does the device require vendor or vendor-authorized service to install patches or software updates?	N/A	—			
CSUP-5.3	Does the device have the capability to receive remote installation of patches or software updates?	N/A	—			
CSUP-5.4	Does the medical device manufacturer allow security updates from any third-party manufacturers (e.g., Microsoft) to be installed without approval from the manufacturer?	N/A	—			
CSUP-6	Does the device contain other software components (e.g., asset management software, license management)? If yes, please provide details or reference in notes and complete 6.1-6.4.	No	—			
CSUP-6.1	Does the device documentation provide instructions for owner/operator installation of patches or software updates?	N/A	—			
CSUP-6.2	Does the device require vendor or vendor-authorized service to install patches or software updates?	N/A	—			
CSUP-6.3	Does the device have the capability to receive remote installation of patches or software updates?	N/A	—			
CSUP-6.4	Does the medical device manufacturer allow security updates from any third-party manufacturers (e.g., Microsoft) to be installed without approval from the manufacturer?	N/A	—			
CSUP-7	Does the manufacturer notify the customer when updates are approved for installation?	Yes	—			
CSUP-8	Does the device perform automatic installation of software updates?	No	—			
CSUP-9	Does the manufacturer have an approved list of third-party software that can be installed on the device?	No	—			
CSUP-10	Can the owner/operator install manufacturer-approved third-party software on the device themselves?	Yes	—			
CSUP-10.1	Does the system have mechanism in place to prevent installation of unapproved software?	See Notes	In KIOSK Mode by default. Must exit KIOSK mode and have Windows admin access to install any third party SW.			
CSUP-11	Does the manufacturer have a process in place to assess device vulnerabilities and updates?	Yes	—			
CSUP-11.1	Does the manufacturer provide customers with review and approval status of updates?	Yes	—			
CSUP-11.2	Is there an update review cycle for the device?	No	—			
HEALTH DATA DE-IDENTIFICATION (DIDT) <i>The ability of the device to directly remove information that allows identification of a person.</i>				IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
DIDT-1	Does the device provide an integral capability to de-identify personally identifiable information?	Yes	Data can be exported anonymized	Section 5.6, DIDT	None	ISO 27038
DIDT-1.1	Does the device support de-identification profiles that comply with the DICOM standard for de-identification?	N/A	—	Section 5.6, DIDT	None	ISO 27038
DATA BACKUP AND DISASTER RECOVERY (DTBK) <i>The ability to recover after damage or destruction of device data, hardware, software, or site configuration information.</i>				IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
DTBK-1	Does the device maintain long term primary storage of personally identifiable information / patient information (e.g. PACS)?	Yes	—			
DTBK-2	Does the device have a "factory reset" function to restore the original device settings as provided by the manufacturer?	Yes	—	Section 5.7, DTBK	CP-9	A.12.3.1
DTBK-3	Does the device have an integral data backup capability to removable media?	Yes	Data backup to USB drive	Section 5.7, DTBK	CP-9	A.12.3.1
DTBK-4	Does the device have an integral data backup capability to remote storage?	No	—			
DTBK-5	Does the device have a backup capability for system configuration information, patch restoration, and software restoration?	See Notes	System configuration/Settings backup to USB drive			
DTBK-6	Does the device provide the capability to check the integrity and authenticity of a backup?	No	—	Section 5.7, DTBK	CP-9	A.12.3.1
EMERGENCY ACCESS (EMRG) <i>The ability of the device user to access personally identifiable information in case of a medical emergency situation that requires immediate access to stored personally identifiable information.</i>				IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
EMRG-1	Does the device incorporate an emergency access (i.e. "break-glass") feature?	No	—	Section 5.8, EMRG	SI-17	None
HEALTH DATA INTEGRITY AND AUTHENTICITY (IGAU) <i>How the device ensures that the stored data on the device has not been altered or destroyed in a non-authorized manner and is from the originator.</i>				IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
IGAU-1	Does the device provide data integrity checking mechanisms of stored health data (e.g., hash or digital signature)?	No	—	Section 5.9, IGAU	SC-28	A.18.1.3
IGAU-2	Does the device provide error/failure protection and recovery mechanisms for stored health data (e.g., RAID-5)?	No	—	Section 5.9, IGAU	SC-28	A.18.1.3

			IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
MALWARE DETECTION/PROTECTION (MLDP) <i>The ability of the device to effectively prevent, detect and remove malicious software (malware).</i>			Section 5.10, MLDP		
MLDP-1	Is the device capable of hosting executable software?	Yes	—		A.12.2.1
MLDP-2	Does the device support the use of anti-malware software (or other anti-malware mechanism)? Provide details or reference in notes.	Yes	—	SI-3	A.9.2.3, A.9.4.5, A.12.1.2, A.12.1.4, A.12.5.1
MLDP-2.1	Does the device include anti-malware software by default?	Yes	—	CM-5	A.12.4.1, A.16.1.2, A.16.1.4
MLDP-2.2	Does the device have anti-malware software available as an option?	N/A	—	AU-6	A.12.4.1, A.16.1.2, A.16.1.4
MLDP-2.3	Does the device documentation allow the owner/operator to install or update anti-malware software?	See Notes	Requires PulmOne's approval	CP-10	A.17.1.2
MLDP-2.4	Can the device owner/operator independently (re-) configure anti-malware settings?	See Notes	Requires PulmOne's approval	AU-2	None
MLDP-2.5	Does notification of malware detection occur in the device user interface?	Yes	—		
MLDP-2.6	Can only manufacturer-authorized persons repair systems when malware has been detected?	Yes	—		
MLDP-2.7	Are malware notifications written to a log?	Yes	—		
MLDP-2.8	Are there any restrictions on anti-malware (e.g., purchase, installation, configuration, scheduling)?	See Notes	Requires PulmOne's approval		
MLDP-3	If the answer to MLDP-2 is NO, and anti-malware cannot be installed on the device, are other compensating controls in place or available?	N/A	—	SI-2	A.12.6.1, A.14.2.2, A.14.2.3, A.16.1.3
MLDP-4	Does the device employ application whitelisting that restricts the software and services that are permitted to be run on the device?	No	—	SI-3	A.12.2.1
MLDP-5	Does the device employ a host-based intrusion detection/prevention system?	No	—	SI-4	None
MLDP-5.1	Can the host-based intrusion detection/prevention system be configured by the customer?	N/A	—	CM-7	A.12.5.1
MLDP-5.2	Can a host-based intrusion detection/prevention system be installed by the customer?	See Notes	Requires PulmOne's approval		
			Section 5.10, MLDP		
NODE AUTHENTICATION (NAUT) <i>The ability of the device to authenticate communication partners/nodes.</i>			IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
NAUT-1	Does the device provide/support any means of node authentication that assures both the sender and the recipient of data are known to each other and are authorized to receive transferred information (e.g. Web APIs, SMTP, SNMP)?	No	—	SC-23	None
NAUT-2	Are network access control mechanisms supported (E.g., does the device have an internal firewall, or use a network connection white list)?	Yes	Windows firewall	SC-7	A.13.1.1, A.13.1.3, A.13.2.1, A.14.1.3
NAUT-2.1	Is the firewall ruleset documented and available for review?	No	—		
NAUT-3	Does the device use certificate-based network connection authentication?	No	—		
			Section 5.11, NAUT		
CONNECTIVITY CAPABILITIES (CONN) <i>All network and removable media connections must be considered in determining appropriate security controls. This section lists connectivity capabilities that may be present on the device.</i>			IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
CONN-1	Does the device have hardware connectivity capabilities?	Yes	—		
CONN-1.1	Does the device support wireless connections?	Yes	—		
CONN-1.1.1	Does the device support Wi-Fi?	Yes	WPA2, WPA2 authentication		
CONN-1.1.2	Does the device support Bluetooth?	See Notes	Disabled by default		
CONN-1.1.3	Does the device support other wireless network connectivity (e.g. LTE, Zigbee, proprietary)?	No	—		
CONN-1.1.4	Does the device support other wireless connections (e.g., custom RF controls, wireless detectors)?	No	—		
CONN-1.2	Does the device support physical connections?	Yes	USB		
CONN-1.2.1	Does the device have available RJ45 Ethernet ports?	No	—		
CONN-1.2.2	Does the device have available USB ports?	Yes	The USB port is required for the MiniBox+ device to communicate with the application software. USB drives can be used to export data		
CONN-1.2.3	Does the device require, use, or support removable memory devices?	Yes	—		
CONN-1.2.4	Does the device support other physical connectivity?	No	—		
CONN-2	Does the manufacturer provide a list of network ports and protocols that are used or may be used on the device?	See Notes	Available on request		
CONN-3	Can the device communicate with other systems within the customer environment?	Yes	Printer, HL7 server (optional), network drive (optional)		
CONN-4	Can the device communicate with other systems external to the customer environment (e.g., a service host)?	No	—		
CONN-5	Does the device make or receive API calls?	No	Only during a customer support session		
CONN-6	Does the device require an internet connection for its intended use?	No	—		
CONN-7	Does the device support Transport Layer Security (TLS)?	No	All pulmonary function measurements can be performed offline		
CONN-7.1	Is TLS configurable?	N/A	—		
CONN-8	Does the device provide operator control functionality from a separate device (e.g., telemedicine)?	No	—		
			Section 5.12, PAUT		
PERSON AUTHENTICATION (PAUT) <i>The ability to configure the device to authenticate users.</i>			IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
PAUT-1	Does the device support and enforce unique IDs and passwords for all users and roles (including service accounts)?	Yes	Admin and general roles, each user has an individual user account and password	IA-2	A.9.2.1
PAUT-1.1	Does the device enforce authentication of unique IDs and passwords for all users and roles (including service accounts)?	Yes	—	IA-2	A.9.2.1
PAUT-2	Is the device configurable to authenticate users through an external authentication service (e.g., MS Active Directory, NDS, LDAP, OAuth, etc.)?	No	—	IA-5	A.9.2.1
PAUT-3	Is the device configurable to lock out a user after a certain number of unsuccessful logon attempts?	Yes	After 5 attempts	IA-2	A.9.2.1
PAUT-4	Are all default accounts (e.g., technician service accounts, administrator accounts) listed in the documentation?	No	—		A.14.1.1, A.14.2.7, A.14.2.9, A.15.1.2
PAUT-5	Can all passwords be changed?	Yes	—	SA-4(5)	A.15.1.2
PAUT-6	Is the device configurable to enforce creation of user account passwords that meet established (organization specific) complexity rules?	Yes	Length of 8-10 characters		
PAUT-7	Does the device support account passwords that expire periodically?	Yes	4 or more character types (uppercase, lowercase, digit, special character)	IA-2	A.9.2.1
PAUT-8	Does the device support multi-factor authentication?	No	Passwords expire after 90 days		
PAUT-9	Does the device support single sign-on (SSO)?	No	—	IA-2	A.9.2.1
PAUT-10	Can user accounts be disabled/locked on the device?	Yes	Administrators can add/edit/delete general accounts	IA-2	A.9.2.1
PAUT-11	Does the device support biometric controls?	No	—	IA-2	A.9.2.1
PAUT-12	Does the device support physical tokens (e.g. badge access)?	No	—		
PAUT-13	Does the device support group authentication (e.g. hospital teams)?	No	—		
PAUT-14	Does the application or device store or manage authentication credentials?	Yes	—		
PAUT-14.1	Are credentials stored using a secure method?	Yes	—		
			Section 5.12, PAUT		
PHYSICAL LOCKS (PLOK) <i>Physical locks can prevent unauthorized users with physical access to the device from compromising the integrity and confidentiality of personally identifiable information stored on the device or on removable media</i>			IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
PLOK-1	Is the device software only? If yes, answer "N/A" to remaining questions in this section.	No	—	PE- 3(4)	A.11.1.1, A.11.1.2, A.11.1.3
PLOK-2	Are all device components maintaining personally identifiable information (other than removable media) physically secure (i.e., cannot remove without tools)?	No	—	PE- 3(4)	A.11.1.1, A.11.1.2, A.11.1.3
PLOK-3	Are all device components maintaining personally identifiable information (other than removable media) physically secured behind an individually keyed locking device?	No	—	PE- 3(4)	A.11.1.1, A.11.1.2, A.11.1.3
PLOK-4	Does the device have an option for the customer to attach a physical lock to restrict access to removable media?	No	—	PE- 3(4)	A.11.1.1, A.11.1.2, A.11.1.3
			Section 5.13, PLOK		
ROADMAP FOR THIRD PARTY COMPONENTS IN DEVICE LIFE CYCLE (RDMP) <i>Manufacturer's plans for security support of third-party components within the device's life cycle.</i>			IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
RDMP-1	Was a secure software development process, such as ISO/IEC 27034 or IEC 62304, followed during product development?	Yes	IEC 62304	CM-2	None
RDMP-2	Does the manufacturer evaluate third-party applications and software components included in the device for secure development practices?	See Notes	Verified at the unit and system level and the software is validated to ensure end-to-end device functionality	CM-8	A.8.1.1, A.8.1.2
RDMP-3	Does the manufacturer maintain a web page or other source of information on software support dates and updates?	No	—	CM-8	A.8.1.1, A.8.1.2
RDMP-4	Does the manufacturer have a plan for managing third-party component end-of-life?	Yes	—	CM-8	A.8.1.1, A.8.1.2
			Section 5.14, RDMP		
SOFTWARE BILL OF MATERIALS (SBOM) <i>A Software Bill of Material (SBOM) lists all the software components that are incorporated into the device being described for the purpose of operational security planning by the healthcare delivery organization. This section supports controls in the RDMP section.</i>			IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013
SBOM-1	Is the SBOM for this product available?	Yes	All third party SW components		
SBOM-2	Does the SBOM follow a standard or common method in describing software components?	Yes	—		
SBOM-2.1	Are the software components identified?	Yes	—		
SBOM-2.2	Are the developers/manufacturers of the software components identified?	Yes	—		
SBOM-2.3	Are the major version numbers of the software components identified?	Yes	—		

PulmOne Advanced Medical Devices, Ltd	MiniBox+, SW Versions 3.2.0.0 to 3.3.0.0	PUO-DOCXXXX	30-Jan-2025
SBOM-2.4	Are any additional descriptive elements identified?	Yes	License type, Copyright Notices
SBOM-3	Does the device include a command or process method available to generate a list of software components installed on the device?	No	---
SBOM-4	Is there an update process for the SBOM?	Yes	---
SYSTEM AND APPLICATION HARDENING (SAHD) <i>The device's inherent resistance to cyber attacks and malware.</i>			
SAHD-1	Is the device hardened in accordance with any industry standards?	See Notes	Surface Go 3 meets NIST CSF
SAHD-2	Has the device received any cybersecurity certifications?	No	---
SAHD-3	Does the device employ any mechanisms for software integrity checking	Yes	---
SAHD-3.1	Does the device employ any mechanism (e.g., release-specific hash key, checksums, digital signature, etc.) to ensure the installed software is manufacturer-authorized?	Yes	---
SAHD-3.2	Does the device employ any mechanism (e.g., release-specific hash key, checksums, digital signature, etc.) to ensure the software updates are the manufacturer-authorized updates?	Yes	---
SAHD-4	Can the owner/operator perform software integrity checks (i.e., verify that the system has not been modified or tampered with)?	No	---
SAHD-5	Is the system configurable to allow the implementation of file-level, patient level, or other types of access controls?	Yes	Limit operator access to patient data
SAHD-5.1	Does the device provide role-based access controls?	Yes	Admin and general, doctor and technician
SAHD-6	Are any system or user accounts restricted or disabled by the manufacturer at system delivery?	Yes	SW operates in Kiosk mode. The operators can only run the MiniBox application.
SAHD-6.1	Are any system or user accounts configurable by the end user after initial configuration?	Yes	End user admins can add/edit/delete user accounts
SAHD-6.2	Does this include restricting certain system or user accounts, such as service technicians, to least privileged access?	Yes	---
SAHD-7	Are all shared resources (e.g., file shares) which are not required for the intended use of the device disabled?	No	---
SAHD-8	Are all communication ports and protocols that are not required for the intended use of the device disabled?	No	---
SAHD-9	Are all services (e.g., telnet, file transfer protocol [FTP], internet information server [IIS], etc.), which are not required for the intended use of the device deleted/disabled?	No	---
SAHD-10	Are all applications (COTS applications as well as OS-included applications, e.g., MS Internet Explorer, etc.) which are not required for the intended use of the device deleted/disabled?	No	A Windows admin password is needed to access them
SAHD-11	Can the device prohibit boot from uncontrolled or removable media (i.e., a source other than an internal drive or memory component)?	Yes	---
SAHD-12	Can unauthorized software or hardware be installed on the device without the use of physical tools?	Yes	Only when aborting KIOSK mode and entering to Windows. A Windows admin password is needed to access them.
SAHD-13	Does the product documentation include information on operational network security scanning by users?	No	---
SAHD-14	Can the device be hardened beyond the default provided state?	No	---
SAHD-14.1	Are instructions available from vendor for increased hardening?	No	---
SHAD-15	Can the system prevent access to BIOS or other bootloaders during boot?	No	---
SAHD-16	Have additional hardening methods not included in 2.3.19 been used to harden the device?	No	---

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013

CM-7	A.12.5.1*
AC-17(2)/IA-3	A.6.2.1, A.6.2.2, A.13.1.1, A.13.2.1, A.14.1.2/None
SA-12(10)	A.14.2.7, A.15.1.1, A.15.1.2, A.15.1.3
CM-8	A.8.1.1, A.8.1.2
AC-3	A.6.2.2, A.9.1.2, A.9.4.1, A.9.4.4, A.9.4.5, A.13.1.1, A.14.1.2, A.14.1.3, A.18.1.3
CM-7	A.12.5.1*
CM-7	A.12.5.1*
CM-8	A.8.1.1, A.8.1.2
CM-7	A.12.5.1*
CM-7	A.12.5.1*
CM-7	A.12.5.1*
SA-18	None
CM-6	None
SI-2	A.12.6.1, A.14.2.2, A.14.2.3, A.16.1.3

SECURITY GUIDANCE (SGUD) <i>Availability of security guidance for operator and administrator of the device and manufacturer sales and service.</i>			
SGUD-1	Does the device include security documentation for the owner/operator?	No	---
SGUD-2	Does the device have the capability, and provide instructions, for the permanent deletion of data from the device or media?	Yes	---
SGUD-3	Are all access accounts documented?	Yes	---
SGUD-3.1	Can the owner/operator manage password control for all accounts?	Yes	---
SGUD-4	Does the product include documentation on recommended compensating controls for the device?	No	---

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013

AT-2/PL-2	A.7.2.2, A.12.2.1/A.14.1.1
MP-6	A.8.2.3, A.8.3.1, A.8.3.2, A.11.2.7
AC-6,IA-2	A.9.1.2, A.9.2.3, A.9.4.4, A.9.4.5/A.9.2.1

HEALTH DATA STORAGE CONFIDENTIALITY (STCF) <i>The ability of the device to ensure unauthorized access does not compromise the integrity and confidentiality of personally identifiable information stored on the device or removable media.</i>			
STCF-1	Can the device encrypt data at rest?	Yes	---
STCF-1.1	Is all data encrypted or otherwise protected?	Yes	BitLocker and/or SQLite database encryption
STCF-1.2	Is the data encryption capability configured by default?	See Notes	Set up during device install
STCF-1.3	Are instructions available to the customer to configure encryption?	No	---
STCF-2	Can the encryption keys be changed or configured?	No	---
STCF-3	Is the data stored in a database located on the device?	Yes	SQLite
STCF-4	Is the data stored in a database external to the device?	No	---

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013

SC-28	A.8.2.3
SC-28	A.8.2.3

TRANSMISSION CONFIDENTIALITY (TXCF) <i>The ability of the device to ensure the confidentiality of transmitted personally identifiable information.</i>			
TXCF-1	Can personally identifiable information be transmitted only via a point-to-point dedicated cable?	No	---
TXCF-2	Is personally identifiable information encrypted prior to transmission via a network or removable media?	No	---
TXCF-2.1	If data is not encrypted by default, can the customer configure encryption options?	No	The device supports only HL7 connection to one specific HL7 server destination
TXCF-3	Is personally identifiable information transmission restricted to a fixed list of network destinations?	Yes	---
TXCF-4	Are connections limited to authenticated systems?	No	---
TXCF-5	Are secure transmission methods supported/implemented (DICOM, HL7, IEEE 11073)?	See Notes	Only HL7 is supported, not encrypted

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013

CM-7	A.12.5.1
CM-7	A.12.5.1
CM-7	A.12.5.1
CM-7	A.12.5.1

TRANSMISSION INTEGRITY (TXIG) <i>The ability of the device to ensure the integrity of transmitted data.</i>			
TXIG-1	Does the device support any mechanism (e.g., digital signatures) intended to ensure data is not modified during transmission?	No	---
TXIG-2	Does the device include multiple sub-components connected by external cables?	See Notes	The MiniBox+ is comprised of the main device, a Hand-Held Unit (RS485 cable), and a tablet (USB cable)

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013

SC-8	A.8.2.3, A.13.1.1, A.13.2.1, A.13.2.3, A.14.1.2, A.14.1.3
------	---

REMOTE SERVICE (RMOT) <i>Remote service refers to all kinds of device maintenance activities performed by a service person via network or other remote connection.</i>			
RMOT-1	Does the device permit remote service connections for device analysis or repair?	See Notes	We can provide remote support via TeamViewer or any customer-approved software (Citrix, MS Teams), upon the customer granting us access.
RMOT-1.1	Does the device allow the owner/operator to initiate remote service sessions for device analysis or repair?	See Notes	End user permission is required to initiate a remote session
RMOT-1.2	Is there an indicator for an enabled and active remote session?	Yes	---
RMOT-1.3	Can patient data be accessed or viewed from the device during the remote session?	Yes	---
RMOT-2	Does the device permit or use remote service connections for predictive maintenance data?	No	---
RMOT-3	Does the device have any other remotely accessible functionality (e.g. software updates, remote training)?	No	---

IEC TR 80001-2-2:2012	NIST SP 800-53 Rev. 4	ISO 27002:2013	
	AC-17	A.6.2.1, A.6.2.2, A.13.1.1, A.13.2.1, A.14.1.2	
	AC-17	A.6.2.1, A.6.2.2, A.13.1.1, A.13.2.1, A.14.1.2	

OTHER SECURITY CONSIDERATIONS (OTHR)			
OTHR-1	Are the stored passwords protected?	Yes	MinBox+ software user passwords are encrypted in the local database
OTHR-2	Can the device be enrolled in a Mobile Device Management (MDM) solution?	See Notes	Requires PulmOne's approval
OTHR-3	Can the device be managed by an Active Directory?	See Notes	Requires PulmOne's approval

IEC TR 80001-2-2:2012

NIST SP 800-53 Rev. 4

ISO 27002:2013